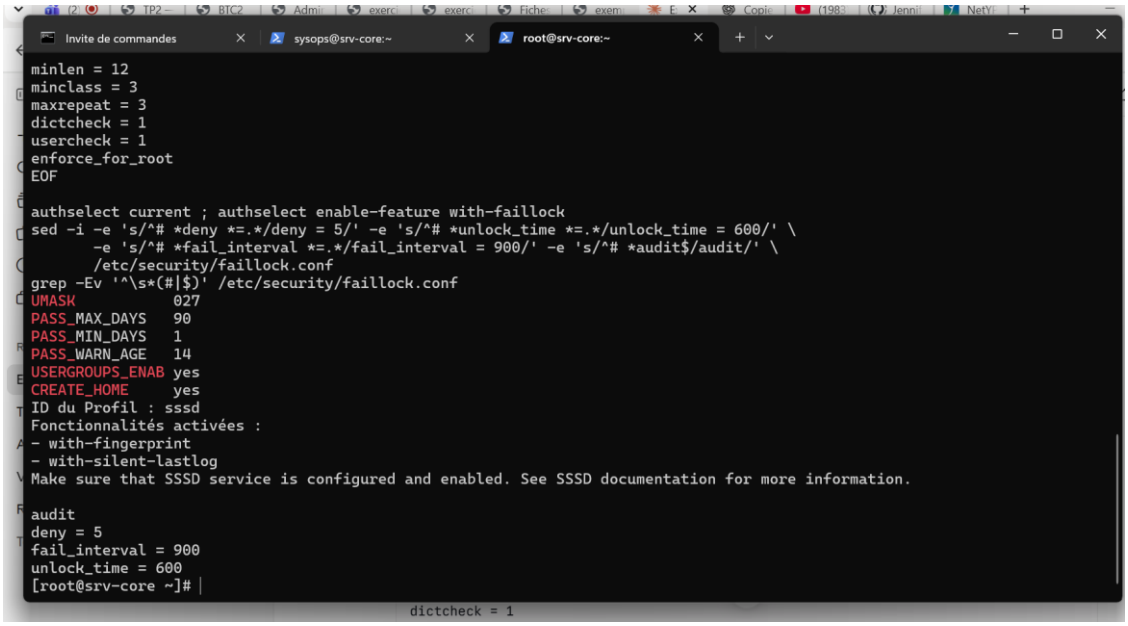
TP2 - Gestion avancée des utilisateurs et des groupes

Fait sur srv-core (Rocky Linux 9.8). Comptes : julien et nadia (transport), tarek (telemetry), audit-ext (auditeur).

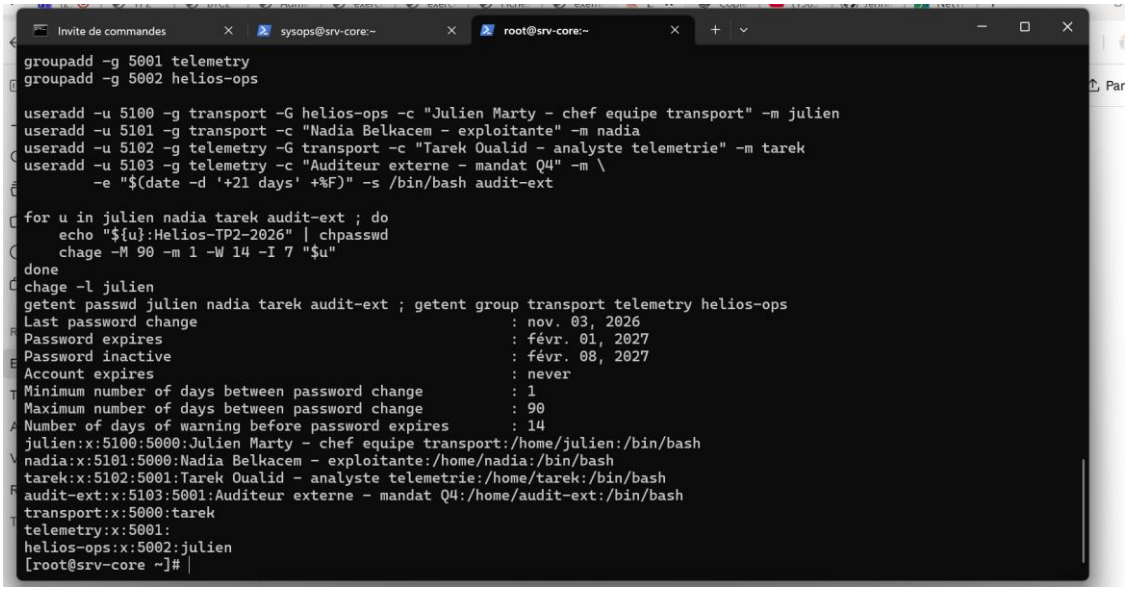
Mission 1 - Comptes et politique d'authentification

1.1 Régler la politique avant de créer les comptes



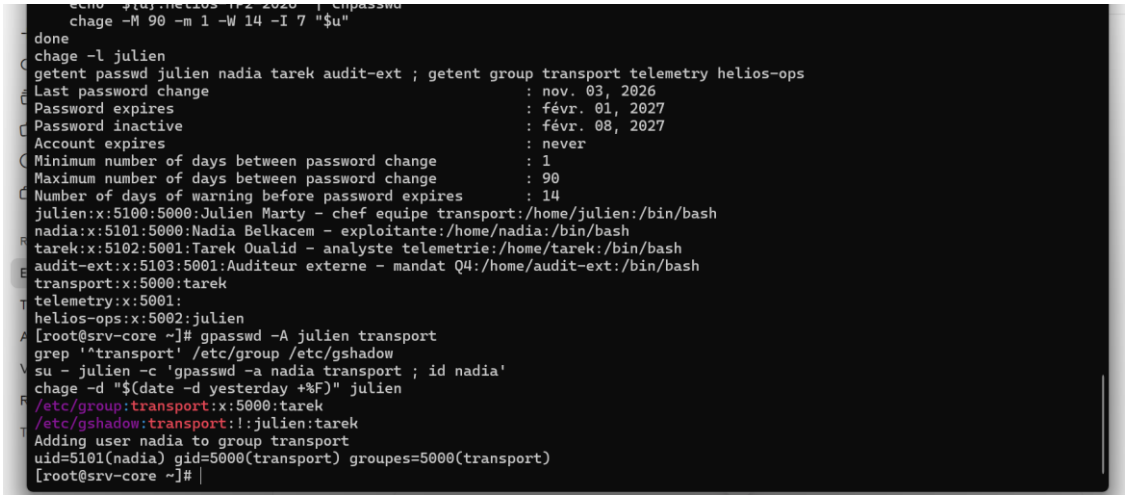
On règle la politique avant de créer les comptes : mot de passe 90 jours, umask 027, 12 caractères minimum, blocage après 5 essais ratés.

1.2 Squelette, groupes et comptes

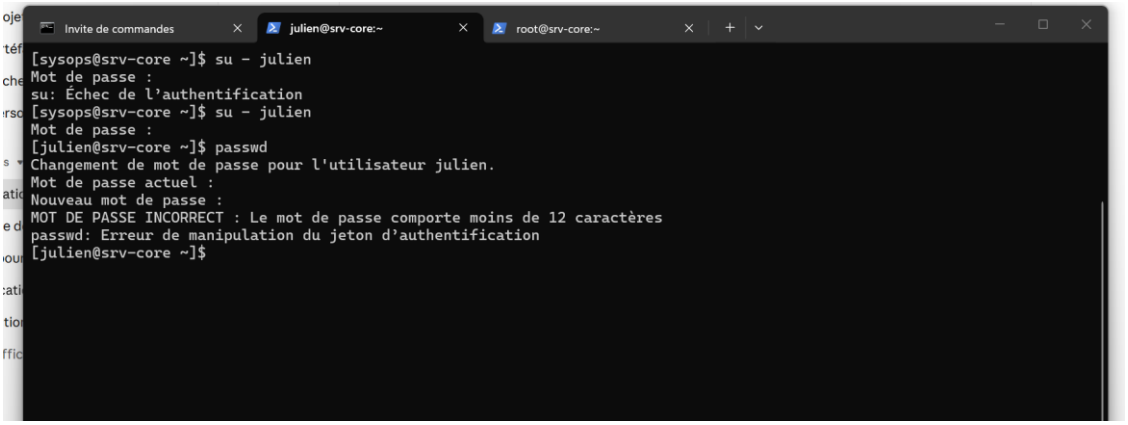


Création des 4 comptes et des 3 groupes. chage -l julien donne bien 90 jours max et 14 jours d'avertissement.

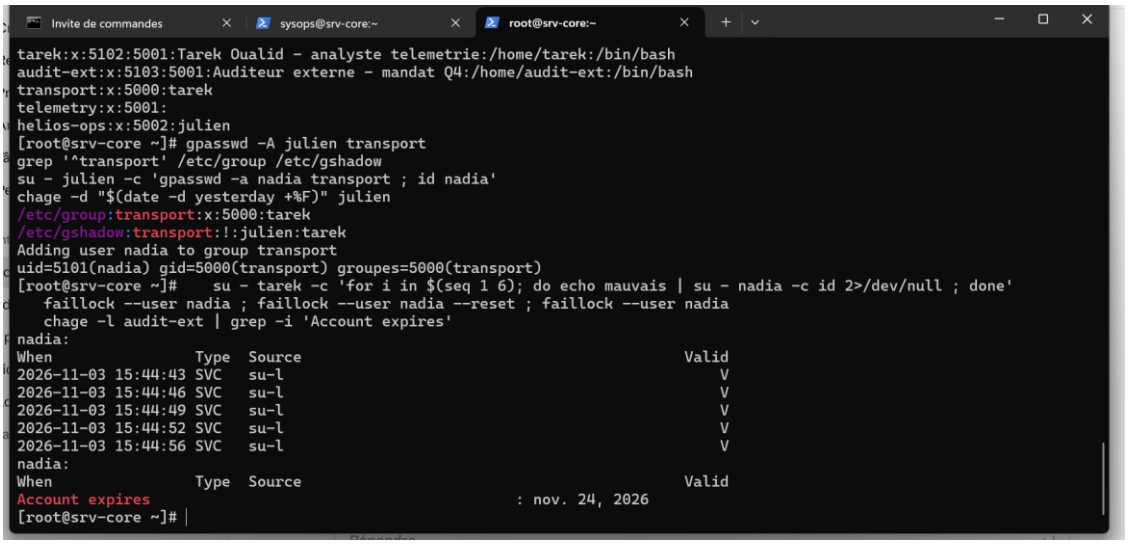
1.3 Administrateur de groupe et vérifications



Julien est admin du groupe transport, il a pu ajouter Nadia sans être root.



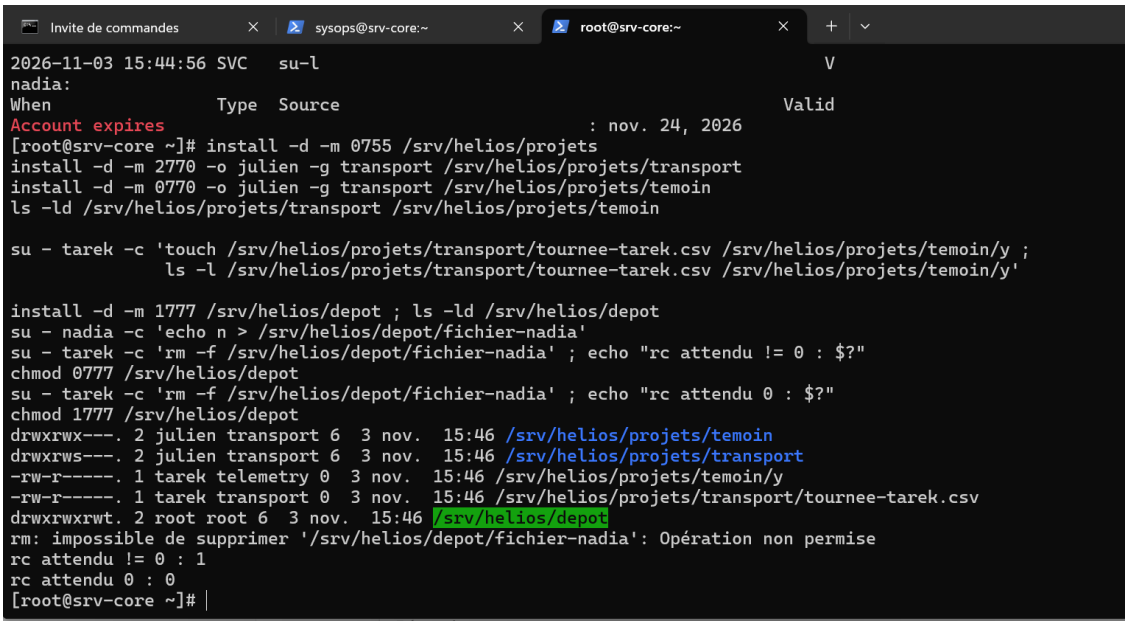
Le mot de passe « helios » est refusé (moins de 12 caractères).



5 échecs enregistrés pour Nadia, puis plus rien après le reset. Le compte audit-ext expire le 24/11/2026.

Mission 2 - Bits spéciaux et umask

2.1 Répertoire setgid et dépôt sticky

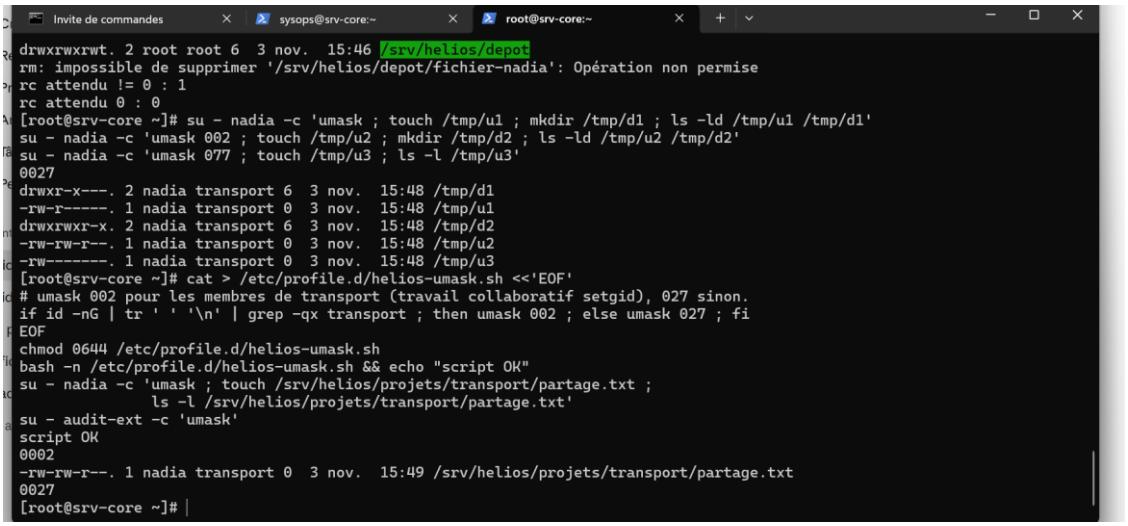


Dans transport (setgid), le fichier de Tarek est au groupe transport, dans temoin il reste en telemetry. Dans depot (sticky), Tarek n'arrive pas à supprimer le fichier de Nadia. En 0777 il peut.

2.2 umask : prédire avant de mesurer

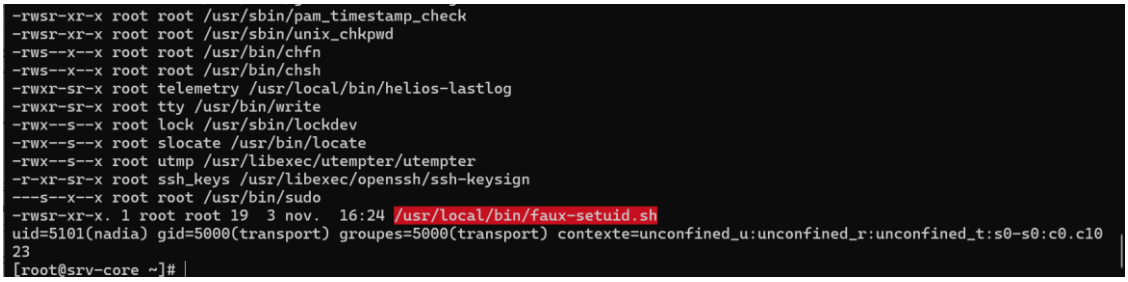
Droits prévus avant de lancer les commandes, puis droits obtenus :

Cas	umask	Prévu	Obtenu
1	0027	fichier 640, dossier 750	-rw-r----- / drwxr-x---
2	002	fichier 664, dossier 775	-rw-rw-r-- / drwxrwxr-x
3	077	fichier 600	-rw-------

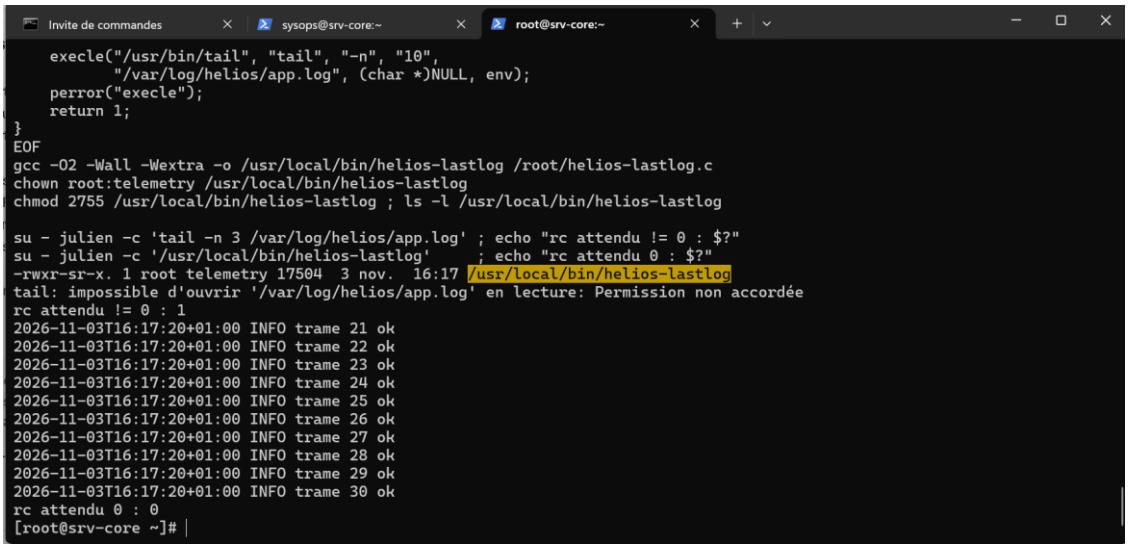


Les résultats sont ceux prévus. Avec le script dans profile.d, Nadia passe en 0002 et partage.txt est en -rw-rw-r--. audit-ext reste en 0027.

2.3 setuid : inventaire, échec, usage légitime



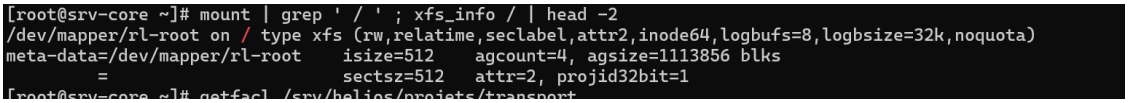
Fin de l'inventaire setuid/setgid. sudo en a besoin pour devenir root, unix_chkpwd pour lire /etc/shadow, chsh pour modifier /etc/passwd. Le faux script setuid tourne quand même en nadia, le noyau ignore le bit sur les scripts.



helios-lastlog est en setgid telemetry. Julien ne peut pas lire app.log avec tail mais il y arrive avec helios-lastlog.

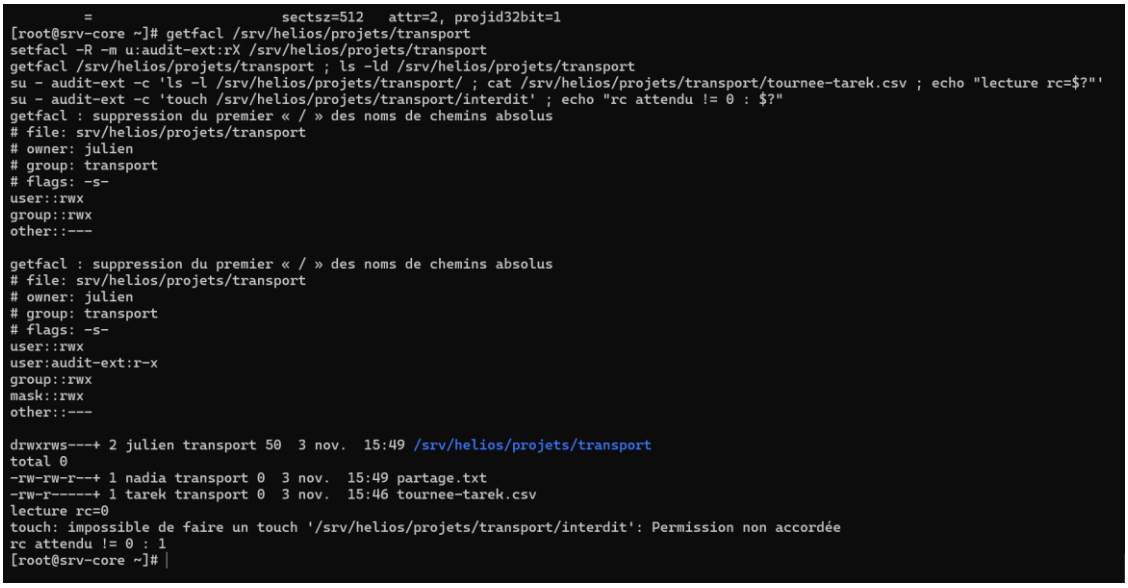
Mission 3 - ACL

Vérification du système de fichiers



La racine est en XFS, les ACL marchent sans option de montage.

3.1 Accès nominatif hors du groupe



On voit la ligne user:audit-ext:r-x et le « + » sur le dossier. L'auditeur peut lire mais pas créer de fichier.

3.2 ACL par défaut

```
rc attendu 0 : 0
[root@srv-core ~]# client_loop: send disconnect: Connection reset
PS C:\Users\jennifer> ssh sysops@192.168.56.10
sysops@192.168.56.10's password:
Activate the web console with: systemctl enable --now cockpit.socket

Last login: Tue Nov  3 12:18:18 2026 from 192.168.56.0
[sysops@srv-core ~]$ sudo -i
[sudo] Mot de passe de sysops :
[root@srv-core ~]# ls -l /srv/helios/projets/transport/nouvelle.csv ; getfacl -c /srv/helios/projets/transport/nouvelle.csv
su - audit-ext -c 'cat /srv/helios/projets/transport/nouvelle.csv' ; echo "avant ACL par défaut, rc=$?"
-rw-r-----. 1 nadia transport 0  3 nov.  16:31 /srv/helios/projets/transport/nouvelle.csv
getfacl : suppression du premier « / » des noms de chemins absolus
user::rw-
group::r--
other::---

cat: /srv/helios/projets/transport/nouvelle.csv: Permission non accordée
avant ACL par défaut, rc=1
[root@srv-core ~]#
```

Avant les ACL par défaut, nouvelle.csv n'a pas de ligne pour audit-ext et il ne peut pas le lire.

```
Invite de commandes | sysops@srv-core:~ | root@srv-core:~
default:user:audit-ext:r--
default:group::rwx
default:group:transport:rwx
default:mask::rwx
default:other::---

getfacl : suppression du premier « / » des noms de chemins absolus
# file: srv/helios/projets/transport/tournee-j2.csv
# owner: nadia
# group: transport
user::rw-
user:audit-ext:r--
group::rwx                      #effective:rw-
group:transport:rwx             #effective:rw-
mask::rw-
other::---

getfacl : suppression du premier « / » des noms de chemins absolus
# file: srv/helios/projets/transport/semaine-41
# owner: nadia
# group: transport
# flags: -s-
user::rwx
user:audit-ext:r--
group::rwx
group:transport:rwx
mask::rwx
other::---
default:user::rwx
default:user:audit-ext:r--
default:group::rwx
default:group:transport:rwx
default:mask::rwx
default:other::---

rc attendu 0 : 0
[root@srv-core ~]#
```

Après, tournee-j2.csv récupère tout seul l'ACL de l'auditeur et il peut le lire. semaine-41 garde aussi les lignes default.

3.3 Le piège du masque

```
[root@srv-core ~]# setfacl -m u:tarek:rwx /srv/helios/projets/transport/tournee-j2.csv
getfacl /srv/helios/projets/transport/tournee-j2.csv
chmod g-w /srv/helios/projets/transport/tournee-j2.csv
getfacl /srv/helios/projets/transport/tournee-j2.csv
su - tarek -c 'echo x >> /srv/helios/projets/transport/tournee-j2.csv' ; echo "rc=$?"
setfacl -m m::rwx /srv/helios/projets/transport/tournee-j2.csv
su - tarek -c 'echo x >> /srv/helios/projets/transport/tournee-j2.csv' ; echo "rc attendu 0 : $?"
getfacl : suppression du premier « / » des noms de chemins absolus
# file: srv/helios/projets/transport/tournee-j2.csv
# owner: nadia
# group: transport
user::rw-
user:tarek:rwx
user:audit-ext:r--
group::rwx
group:transport:rwx
mask::rwx
other::---

getfacl : suppression du premier « / » des noms de chemins absolus
# file: srv/helios/projets/transport/tournee-j2.csv
# owner: nadia
# group: transport
user::rw-
user:tarek:rwx                  #effective:r-x
user:audit-ext:r--
group::rwx                      #effective:r-x
group:transport:rwx             #effective:r-x
mask::r-x
other::---

-bash: ligne 1: /srv/helios/projets/transport/tournee-j2.csv: Permission non accordée
rc=1
rc attendu 0 : 0
[root@srv-core ~]#
```

Tarek a rwx, mais après chmod g-w le mask passe à r-x (#effective:r-x) et il ne peut plus écrire. Ça remarche après setfacl -m m::rwx.

Ce que chmod g-w a changé : sur un fichier avec des ACL, chmod g touche le mask et pas le groupe. Le mask limite toutes les ACL, donc Tarek et le groupe perdent l'écriture même si leurs lignes n'ont pas bougé.

3.4 Sauvegarder, restaurer et copier les ACL

```
cd
# file: transport
# owner: julien
# group: transport
# flags: -s-
user::rwx
group::rwx
other::---

Warning: option --restore=file is unsafe without option -P (--physical) as it traverses symbolic links in pathnames
# file: transport
# owner: julien
# group: transport
# flags: -s-
user::rwx
user:audit-ext:r-x
group::rwx
mask::rwx
other::---
default:user::rwx
# file: transport-copie
# owner: julien
# group: transport
# flags: -s-
user::rwx
user:audit-ext:r-x
group::rwx
mask::rwx
other::---
default:user::rwx
# file: transport-copie2
# owner: root
# group: root
user::rwx
group::r-x
other::---
```

Sauvegarde avec getfacl -R, suppression avec setfacl -b, puis restauration. cp -a garde les ACL, cp -r les perd (et aussi le propriétaire, le groupe et le setgid).

Mission 4 - Délégation sudo

4.1 Règle restreinte pour helios-ops

```
%helios-ops  ALL = !DANGEREUX
EOF
chmod 0440 /etc/sudoers.d/90-helios-ops
visudo -cf /etc/sudoers.d/90-helios-ops
install -d -m 0700 /var/log/sudo-io
/etc/sudoers.d/90-helios-ops : analyse réussie
[root@srv-core ~]#
```

Fichier 90-helios-ops en 0440, validé par visudo.

4.2 Vérifier, tracer, rejouer

```
[root@srv-core ~]# visudo -c
sudo -l -U julien
/etc/sudoers : analyse réussie
/etc/sudoers.d/90-helios-ops : analyse réussie
Entrées Defaults correspondant pour julien sur srv-core :
    !visiblepw, always_set_home, match_group_by_gid, always_query_group_plugin, env_reset, env_keep="COLORS DISPLAY HOSTNAME
    HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE
    LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE",
    env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY", secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin,
    timestamp_timeout=5, passwd_tries=2, lecture=always, log_output, iolog_dir=/var/log/sudo-io, logfile=/var/log/sudo-helios.log

L'utilisateur julien peut utiliser les commandes suivantes sur srv-core :
    (root) /usr/bin/systemctl start helios-collect.service, /usr/bin/systemctl stop helios-collect.service, /usr/bin/systemctl
        restart helios-collect.service, /usr/bin/systemctl status helios-collect.service, /usr/bin/systemctl start helios.target,
        /usr/bin/systemctl stop helios.target, /usr/bin/journalctl -u helios-collect.service *, /usr/bin/journalctl -u
        helios-archive.service *
    (helios) /usr/bin/ls /var/lib/helios, /usr/bin/cat /var/lib/helios/telemetry.csv
    (root) !/usr/bin/su, !/usr/bin/sudo, !/usr/bin/passwd root, !/usr/bin/vi, !/usr/bin/vim, !/usr/bin/less, !/usr/bin/find
[root@srv-core ~]#
```

sudo -l -U julien : il peut gérer helios-collect et lire ses logs, lire la télémétrie en helios. su, vim, less, find sont interdits et sshd n'y est pas.

```
[julien@srv-core ~]$ sudo systemctl restart helios-collect.service ; echo "autorise rc=$?"

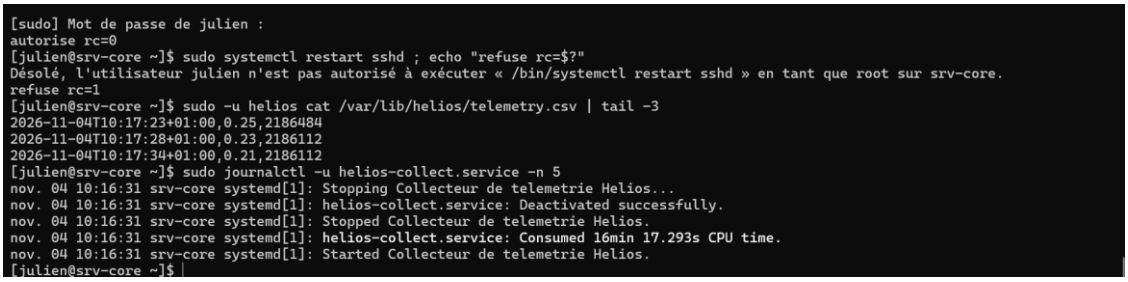
Nous espérons que vous avez reçu de votre administrateur système local
les consignes traditionnelles. Généralement, elles se concentrent sur ces trois éléments :

    #1) Respectez la vie privée des autres.
    #2) Réfléchissez avant d'utiliser le clavier.
    #3) De grands pouvoirs confèrent de grandes responsabilités.

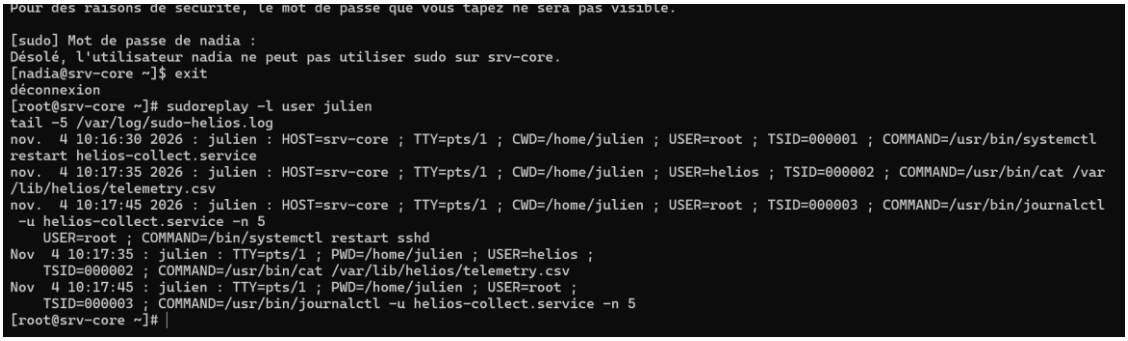
Pour des raisons de sécurité, le mot de passe que vous tapez ne sera pas visible.

[sudo] Mot de passe de julien :
autorise rc=0
[julien@srv-core ~]$
```

Julien redémarre helios-collect avec sudo (rc=0).

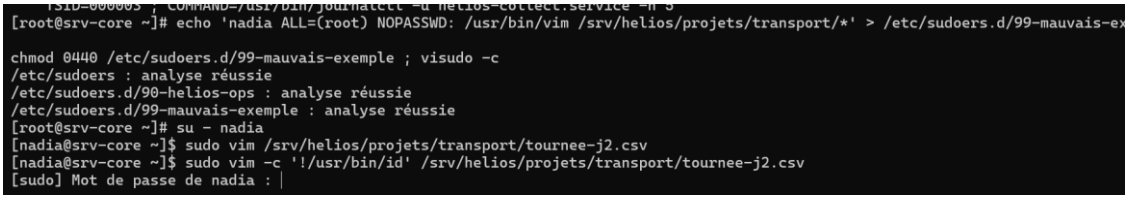


Le restart de sshd est refusé. La lecture de la télémétrie et du journal marchent.

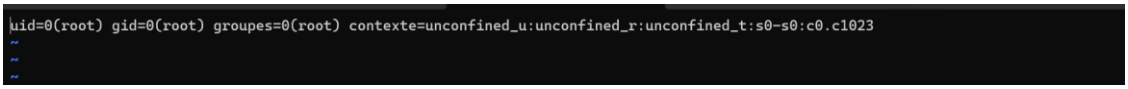


Nadia n'a pas le droit à sudo. sudoreplay montre les 3 sessions de Julien et le log garde aussi le refus pour sshd.

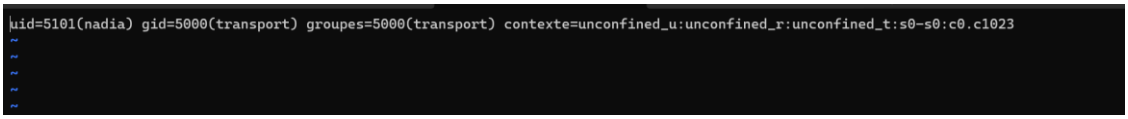
4.3 Une règle laxiste ne protège rien



Mauvaise règle : Nadia peut lancer vim en root sans mot de passe.



Depuis ce vim, !!/usr/bin/id renvoie uid=0(root), donc Nadia peut lancer ce qu'elle veut en root.



Avec sudoedit, la même commande renvoie uid=5101(nadia), la faille est fermée.